Part 3. Human-Centred Security

Alejandro Panigada
2003597

ScottishGlen Resilience Case Study

ScottishGlen is a small sized company. The company's IT department is limited to one IT manager who oversees a group of developers and some technical staff which attends the company's infrastructure. No security-only staff exists at the company.

The company size brings many limitations in both budget an human resources for IT related work.

However, a positive aspect of being a small sized company is that the corresponding small amount of personnel requires less resources to check personnel misconduct and misbehaviour than big companies. Less staff means less resources to check, meaning easier detection for example of insider threats.

The company has been recently receiving a high number of phishing emails from what appears to be a hacktivist group.

A counterattack was asked to the only IT manager present in the company against those phishing email It was also asked to implement an authentication system on company internal applications which at the time of writing completely lack any authentication.

While this lack of security as preferred by the employees due to convenience this pose a high risk to the company in case of an insider threat or in case an external actor obtains access to the network. In the latter case specifically, any actor who gains access to the internals of a network would have free access to all the applications meaning both vertical and horizontal privilege escalation due to lack of authentication.

There are two sides to consider in any attack: A technical side and the human side.

They are non-exclusive meaning that they can be complementary.

Chapter 1 will cover the human and technical side for preventing further compromise on the company's network.

Chapter 2 will discuss what authentication system and the storage of credentials can be used to make the network more secure against both external and internal threats.

1. Human-centred risks

1.1 Insider threats

Insider threats are cybersecurity threats originating from authorized users, such as employees which intentionally misuse their valid access.

There are 3 main types of insider threats (Asasfeh et al., 2024):

- Malicious insiders
  Discontented current or former employees which have active credentials who misuse them for revenge , financial gain or other motivation
- Negligent insiders
  Insiders who do not have any malicious intention but through ignorance they compromise internal security by falling for example for phishing attacks or for saving time they do not respect security protocols.
- Compromised insiders
  Any user where legitimate credentials are stolen by an outside threat, is considered a compromised insider.

1.2 Social Engineering

Social engineering attacks consist in manipulating individuals in sharing private and confidential information or performing actions which compromise personal and organizational security (Salahdine and Kaabouch, 2019).

There are many types of social engineering attacks, one of the most common being phishing which consists in manipulating recipients of a message into sharing sensitive information (Siddiqi et al., 2022).

1.3 Malware

Malware threats consist in possible execution of malicious software, for example trojan horses, ransomware, spyware or any program intentionally created for harming their users.

Organizational threats are (IBM,2026) :

- The possible hold of devices, data or entire networks in hostage for money as is the case of ransomware.
- Unauthorized access to sensitive data or assets
- Stealing of credentials or other valuable information
- Disruption of critical systems

Some types of malware are (IBM, 2026):

- Computer viruses
  A specific kind of malware that spreads by injecting code into legitimate software
- Ransomware
  Malware that locks up device data usually by using encryption and demands payment for the unlocking of it
- Botnets
  Botnets are network of malware-infested devices that are under a malicious actor's control. They are used by cybercriminals to launch for example distributed denial of service attacks
- Rootkits
  Malware which allows attackers to gain privileged access to computer's operating system or any other digital asset. They are used to perform any action desired on the target machine. For example, they can be used to reconfigure applications on the target systems.

From a human-centred perspective, social engineering scams are a common method to execute malware on sensitive machines (Siddiqi et al., 2022).

Another way to have them executed from a human-centred perspective is the usage of personal devices in a corporate environment without any authorization. Malware present in the user's machine can spread without intention into the enterprise environment making the usage of personal devices a high risk (Hakimi et al., 2024).

2. Human-centred recommendations

2.1 User and Entity Behavioural analysis (UEBA)

UEBA is a type of security software that uses behavioural analytics, machine learning algorithms and automation to identify abnormal and dangerous behaviour from users and devices (IBM, 2026)

UEBA is based on user activity monitoring, behavioural analysis and anomaly detection (Khan et al., 2022).

It is extremely useful for insider threats, but it can also find abnormal behaviour in compromised machines when they are controlled by external threats (Bakhit et al., 2025).

Even with limited funds and human resources, the integration of the current setup with an existing UEBA software should be achievable and effective in dealing with the technical side of the problem currently being faced (Shashanka et al., 2016).

2.1 Employee Training

One of the most common mitigation strategies found in literature is improving employee education and awareness (Hakimi et al., 2024).

This consists in allocating resources to educate employees by using several strategies such as simulations, or training programs.

This includes knowledge on how to recognize, avoid, and report phishing or other social engineering attacks (Siddiqi et al., 2022).

While funds in the company are limited, creating barriers to the amount of resources that can be spent on training, a basic awareness campaign should be possible to be performed even with low budget. Because of the limited amount of personnel, training can be done faster and be more effective than in large companies where many factors can alter the effectiveness of the programs (Hakimi et al., 2024).

At the moment, with the company dealing with phishing emails, immediate training and awareness campaign in form of direct notice or posters around the physical headquarters of the company should be enough to keep most of the staff aware.

However, monitoring resources is key as even only one phishing email opened can bring an astonishing amount of damage (Bakhit et al., 2025).

2.2 Data Loss Prevention (DLP)

“Data loss prevention (DLP) is the discipline of shielding sensitive data from theft, loss and misuse by using cybersecurity strategies, processes and technologies. ”(IBM, 2026)

There are many types of DLP, but the suggested typology for ScottisGlen is an endpoint DLP.

An endpoint DLP monitors end devices, such as laptop, servers, mobile devices ecc.

An endpoint DLP is much easier to implement than other solutions and requires only license of a software and subsequent setup. It is also faster to deploy than network or other types of DLP.

Once an unauthorized action is detected on the end device, access to that resource can be blocked.

This is useful for both machines compromised by external attackers and insider threats.

3. Authentication mechanism

3.1 Password-based

Password-based authentication remains the most widely deployed mechanism globally, primarily because of its simplicity and near-zero deployment cost (Yusop et al., 2025).

However, despite the high usage, it is extremely insecure.

Many studies have been conducted in improving password-based authentication by using Second Factor Authentication(2FA) or Multi Factor Authentication (MFA) but they are characterized by the poor usage experience. (Yusop et al,2025)

Software like password managers also face security problematics. (Yusop et al. 2025)

3.2 Multi Factor Authentication (MFA) and Second Factor Authentication (2FA)

MFA verify user's identity by requiring at least two types of different proofs.

For example, mobile banking usually asks biometrics and PIN to ensure proper authorization.

MFA provides an extra layer of protection compared to a single method.

2FA is the most common MFA systems, requiring two pieces of evidence, although MFA can ask for three or more pieces of evidence (IBM, 2026).

2FA, or MFA in general, is capable of delivering high security gains compared to password-only infrastructures.

Thanks to this system attacks such as bruteforce attacks or credential sniffing becomes significantly less effective (Want et. Al, 2024).

Apart from preventing unauthorized access, usage of dynamic credentials, cryptography and other technologies, 2FA has been effective to prevent other more complex attacks such as impersonation attacks. (Wang et. Al, 2024).

However, user experience is poor and in case of poor user experience.

Additionally, 2FA is target of many social engineering attacks.

For example, Siadati et. Al (2017), were able to get 50% of participants in a related study to disclose their Google verification code just by using a carefully spoofed message.

While 2FA benefits are clear, human is still the weakest link and 2FA is not enough to completely address that.

3.3 Behavioural Authentication

Behavioural authentication is an authentication technology which, by collecting behavioural data and analyzing it for unique behavioural patterns, it allows users to be authenticated only by using unique characteristics found in every individual (Wang et. al,2024).

It is based on the concept of behavioural perspective which involves the right agent performing the right actions at the right time under certain conditions (Wang et. Al, 2024).

3.4 Biometrics

Biometrics have distinctive advantages over passwords or physical keys.They can also be integreated with other mechanisms such as PINs as performed in mobile banking (Musa et al., 2025).

However, it can be costly to setup a biometric-based system and it has several inherited problems, the main one being the protection of extracted biometric templates (Musa et al., 2025).

Improper storage of them can make possible impersonation attacks and, since they are unchangeable due to their unique nature, there is no way to assign new templates to users (Still et al., 2017).

4. Authentication recommendations

4.1 ScottishGlen authentication

ScottishGlen has no autentication in place at all. This is a serious vulnerability and any attacker, whether insider or external actor, can escalate inside the network without any restriction and performing any action they want.

This is also risky for their clients, as important data, being an energy company, can be stolen.

Resources are not enough to setup complex setups such as biometric, or even contacting a contractor for 2FA tokens or cards. Also, cards and tokens can be stolen, defeating the purpose.

The most effective way is combining behavioural authentication and a mail/SMS code as part of MFA system mixed with a standard password-based authentication (Wang et al., 2024).

A password policy should also be created to avoid weak password generation.

This setup allows to have a biometric system at low costs compared to iris or fingerprint scanners and be useful in case both one time use code and passwords are compromised (Wang et al., 2024).

REFERENCES

Asasfeh, A. *et al.* (2024) "Human Factors In Security Management: Understanding And Mitigating Insider Threats." Dubai, United Arab Emirates: IEEE, pp. 1–10. Available at: https://doi.org/10.1109/ICCR61006.2024.10532956.

Bakhit, R.S., Abo-alian, A. and Badr, N.L. (2025) "Enhancing Behavioral Insider Threat Detection with AI." Cairo, Egypt: IEEE, pp. 381–388. Available at: https://doi.org/10.1109/ICICIS66182.2025.11313138.

Hakimi, M., Mohammad Mustafa Quchi and Abdul Wajid Fazil (2024) "Human factors in cybersecurity: an in depth analysis of user centric studies," *Jurnal Ilmiah Multidisiplin Indonesia (JIM-ID)*, 3(01), pp. 20–33. Available at: https://doi.org/10.58471/esaprom.v3i01.3832.

IBM (no date) *IBM Think*. IBM. Available at: https://www.ibm.com/think/topics.

Mbaka, W.B., van Gerwen, S. and Tuma, K. (no date) "Human Factors in Security Risk of Software Systems: A Systematic Literature Review."

Musa, K. *et al.* (2025) "Mitigating Cyber Risk and Current Trends in Modern Authentication Techniques for Businesses," 01(03).

Salahdine, F. and Kaabouch, N. (2019) "Social Engineering Attacks: A Survey," *Future Internet*, 11(4), p. 89. Available at: https://doi.org/10.3390/fi11040089.

Shashanka, M., Shen, M.-Y. and Wang, J. (2016) "User and entity behavior analytics for enterprise security." Washington DC,USA: IEEE, pp. 1867–1874. Available at: https://doi.org/10.1109/BigData.2016.7840805.

Siddiqi, Murtaza Ahmed, Pak, W. and Siddiqi, Moquddam A. (2022) "A Study on the Psychology of Social Engineering-Based Cyberattacks and Existing Countermeasures," *Applied Sciences*, 12(12), p. 6042. Available at: https://doi.org/10.3390/app12126042.

Still, J.D., Cain, A. and Schuster, D. (2017) "Human-centered authentication guidelines," *Information & Computer Security*, 25(4), pp. 437–453. Available at: https://doi.org/10.1108/ICS-04-2016-0034.

Wang, C. *et al.* (2024) "Behavioral authentication for security and safety," *Security and Safety*, 3, p. 2024003. Available at: https://doi.org/10.1051/sands/2024003.

Wang, P., Boodraj, M. and Baskerville, R. (2026) "Beyond passwords: A review of the hidden risks in two-factor authentication," *Journal of Systems and Information Technology*, 28(2), pp. 173–202. Available at: https://doi.org/10.1108/JSIT-03-2025-0140.

Yusop, M.I.M. *et al.* (2025) "Advancing Passwordless Authentication: A Systematic Review of Methods, Challenges, and Future Directions for Secure User Identity," *IEEE Access*, 13, pp. 13919–13943. Available at: https://doi.org/10.1109/ACCESS.2025.3528960.

Zunair Ahmed Khan, M., Mubashir Khan, M. and Arshad, J. (2022) "Anomaly Detection and Enterprise Security using User and Entity Behavior Analytics (UEBA)." Karachi, Pakistan: IEEE, pp. 1–9. Available at: https://doi.org/10.1109/ICONICS56716.2022.10100596.